

GRILLE D'AUDIT DES PRESTATAIRES

Évaluation de la sécurité et de la conformité

Référentiel applicable	RGPD (art. 28) NIS 2 DORA ISO 27001 ISO 27036 PCI-DSS
Prestataires évalués	Microsoft Azure BPI France PayPal Stripe
Date d'audit	Juin 2026
Prochaine révision	Juin 2027 (révision annuelle obligatoire)
Classification	CONFIDENTIEL

Légende des réponses

Oui	Mesure en place et opérationnelle	En cours	Mesure en cours de déploiement
Non	Mesure absente – action corrective requise	N/A	Non applicable à ce prestataire

1. Grille d'évaluation par prestataire

Ce tableau recense l'ensemble des critères de sécurité et de conformité évalués pour chacun des quatre prestataires critiques. Les réponses sont issues des questionnaires transmis et des certifications publiquement disponibles.

Question d'audit	Microsoft Azure	BPI France	PayPal	Stripe
I. GOUVERNANCE ET POLITIQUE DE SÉCURITÉ				
1. Disposez-vous d'une politique de sécurité de l'information documentée et approuvée par la direction ?	Oui	Oui	Oui	Oui
2. Cette politique est-elle révisée et mise à jour au moins annuellement ?	Oui	Oui	Oui	Oui
3. Disposez-vous d'un RSSI (Responsable Sécurité SI) désigné ?	Oui	Oui	Oui	Oui
4. Avez-vous un programme de sensibilisation à la cybersécurité pour vos employés ?	Oui	Oui	Oui	Oui
5. Êtes-vous certifié ISO/IEC 27001 ou équivalent ?	Oui	Non	Oui	Oui
II. PROTECTION DES DONNÉES PERSONNELLES (RGPD)				
6. Agissez-vous en qualité de sous-traitant au sens de l'article 28 du RGPD ?	Oui	Oui	Oui	Oui
7. Avez-vous désigné un Délégué à la Protection des Données (DPO) ?	Oui	Oui	Non	Non
8. Disposez-vous d'un registre des activités de traitement ?	Oui	Oui	Oui	Oui
9. Les données personnelles sont-elles hébergées dans l'EEE ?	En cours	Oui	Non	Non
10. En cas de transfert hors UE, des garanties appropriées sont-elles en place (SCC, BCR) ?	Oui	N/A	Oui	Oui
11. Disposez-vous d'une procédure de notification de violation de données (72h CNIL) ?	Oui	Oui	Oui	Oui
12. Garantisiez-vous l'exercice des droits des personnes concernées (art. 15-22 RGPD) ?	Oui	Oui	Oui	Oui
III. SÉCURITÉ TECHNIQUE				
13. Les données clients sont-elles chiffrées au repos (AES-256 ou équivalent) ?	Oui	Oui	Oui	Oui
14. Les communications sont-elles chiffrées en transit (TLS 1.2 minimum) ?	Oui	Oui	Oui	Oui
15. Disposez-vous d'une authentification multifacteur (MFA) pour les accès administrateurs ?	Oui	En cours	Oui	Oui
16. Réalisez-vous des tests d'intrusion (pentests) au moins annuellement ?	Oui	Oui	Oui	Oui
17. Disposez-vous d'un système de détection d'intrusions (IDS/IPS) ?	Oui	Oui	Oui	Oui
18. Avez-vous un processus de gestion des vulnérabilités et de patching ?	Oui	En cours	Oui	Oui
19. Les sauvegardes sont-elles réalisées régulièrement et testées (restauration) ?	Oui	Oui	Oui	Oui
20. Disposez-vous d'un SIEM ou d'un système de surveillance des logs ?	Oui	Oui	Oui	Oui

Question d'audit	Microsoft Azure	BPI France	PayPal	Stripe
IV. CONTINUITÉ D'ACTIVITÉ ET GESTION DES INCIDENTS				
21. Disposez-vous d'un Plan de Continuité d'Activité (PCA) documenté ?	Oui	Oui	Oui	Oui
22. Le PCA est-il testé au moins une fois par an ?	Oui	Oui	En cours	Oui
23. Disposez-vous d'un Plan de Reprise d'Activité (PRA) avec un RTO défini ?	Oui	Oui	Oui	Oui
24. Avez-vous une procédure formalisée de gestion des incidents de sécurité ?	Oui	Oui	Oui	Oui
25. Votre infrastructure est-elle hébergée dans des datacenters redondants ?	Oui	Oui	Oui	Oui
26. Publiez-vous un statut de disponibilité de vos services en temps réel ?	Oui	Non	Oui	Oui
V. GESTION DES ACCÈS ET DES TIERS				
27. Appliquez-vous le principe du moindre privilège pour les accès au SI ?	Oui	Oui	Oui	Oui
28. Réalisez-vous des revues et recertifications des droits d'accès ?	Oui	En cours	Oui	Oui
29. Avez-vous une politique de gestion des accès des sous-traitants tiers ?	Oui	Oui	Oui	Oui
30. Évaluez-vous la sécurité de vos propres fournisseurs (chaîne d'approvisionnement) ?	Oui	Oui	Oui	Oui
VI. CONFORMITÉ RÉGLEMENTAIRE				
31. Êtes-vous conforme aux exigences PCI-DSS (pour les traitements de paiement) ?	Oui	N/A	Oui	Oui
32. Êtes-vous soumis au règlement DORA et en êtes-vous conforme ?	Oui	Oui	En cours	En cours
33. Disposez-vous d'une certification SOC 2 Type II ou équivalent ?	Oui	Non	Oui	Oui
34. Réalisez-vous des audits de sécurité externes annuels ?	Oui	Oui	Oui	Oui

2. Synthèse de l'évaluation

Tableau de verdict global par prestataire, certifications détenues et jugement d'ensemble.

Prestataire	Périmètre de services	Criticité	Certifications / Conformité	Verdict
Microsoft Azure	Infrastructure cloud, stockage, IA, sauvegarde, réseau	Très élevée	ISO 27001, SOC 2, PCI-DSS, DORA	Favorable
BPI France	Financement, garanties, accompagnement bancaire	Élevée	Réglementation bancaire FR, DORA	Acceptable
PayPal	Passerelle de paiement B2C, virements	Élevée	PCI-DSS, SOC 2, DORA (en cours)	Acceptable
Stripe	API paiement, abonnements, facturation B2B	Très élevée	ISO 27001, PCI-DSS, SOC 2, DORA (en cours)	Favorable

Points d'attention identifiés

- › **BPI France** : absence de certification ISO 27001, MFA non généralisé, pas de page de statut public. Niveau de maturité cyber à renforcer compte tenu de son rôle dans le financement de l'organisation.
- › **PayPal & Stripe** : hébergement des données hors EEE (États-Unis). Des clauses contractuelles standard (SCC) sont en place mais doivent être vérifiées et documentées dans le registre des traitements RGPD. Conformité DORA en cours d'intégration.
- › **Microsoft Azure** : prestataire le mieux noté. Infrastructure cloud résiliente avec haute disponibilité multi-régions. Surveiller l'évolution des conditions de transfert de données.

3. Indicateurs de niveau de service (SLA)

Comparaison des engagements contractuels de disponibilité et de reprise pour chaque prestataire. Ces indicateurs doivent être alignés avec les objectifs RTO/RPO du Plan de Continuité d'Activité.

Indicateur SLA	Microsoft Azure	BPI France	PayPal	Stripe
Disponibilité garantie	99,99%	99,5%	99,9%	99,99%
GTI – Garantie de Temps d'Intervention (incidents critiques)	< 15 min	< 4h	< 1h	< 30 min
GTR – Garantie de Temps de Rétablissement (RTO cible)	< 2h	< 8h	< 4h	< 2h
RPO – Objectif de Point de Reprise	< 1h	< 6h	< 4h	< 1h
Notification incident de sécurité (au client)	< 72h	< 72h	< 72h	< 72h
Canal de support prioritaire	Portal + tél. 24/7	Email + conseiller dédié	Dashboard + chat 24/7	Dashboard + API
Pénalités en cas de non-respect	Crédits de service (jusqu'à 100%)	À négocier contractuellement	Crédits de service	Crédits de service
Fréquence de révision du SLA	Annuelle	Annuelle	Annuelle	Annuelle

4. Plan d'action corrective

Actions issues de l'audit à mettre en œuvre pour combler les écarts identifiés. **P1** = immédiat (< 1 mois) | **P2** = court terme (1–3 mois) | **P3** = moyen terme (3–6 mois).

Réf.	Prestataire	Action	Prio.	Délai	Responsable
A01	BPI France	Déployer le MFA sur l'ensemble des accès administrateurs BPI France	P1	< 1 mois	RSSI
A02	PayPal / Stripe	Vérifier et documenter les clauses SCC pour les transferts hors EEE dans le registre DPO	P1	< 1 mois	DPO
A03	Tous	Réviser et signer les DPA (Data Processing Agreements) mis à jour pour tous les prestataires	P1	< 1 mois	DPO
A04	BPI France	Formaliser et tester annuellement le PCA partenaire BPI France	P2	3 mois	DSI

Réf.	Prestataire	Action	Prio.	Délai	Responsable
A05	BPI France	Exiger la recertification des droits d'accès (audit des habilitations)	P2	3 mois	RSSI
A06	PayPal / Stripe	Intégrer la conformité DORA dans les SLA lors de la prochaine révision contractuelle	P2	6 mois	DAF / DPO
A07	BPI France	Exiger la publication d'un statut de disponibilité des services en temps réel	P3	6 mois	DSI
A08	Tous	Planifier les audits annuels prestataires et transmettre la grille à chaque renouvellement SLA	P2	Annuel	RSSI

Ce plan d'action fera l'objet d'un suivi trimestriel par le RSSI. Un rapport d'avancement sera présenté au Comité de Direction lors de chaque point de gouvernance. La prochaine révision complète de la grille d'audit est prévue en juin 2027.